Informe de pruebas de seguridad de software

1 Portada

Curso: Pruebas de Software

Código del curso: ISW-622

Integrantes: Wilberth Guillen y Jania Hernández Dormuz

Grupo: Sábados

Fecha de entrega: 30 de octubre de 2026

Nombre del proyecto: laboratorio-pruebas-seguridad

Versión del proyecto: W1 sobre la base 9525e75; cambios de Wilberth identificados en evidencias/version_bloque_wilberth.json

Autor del documento: Wilberth Guillen

Fecha del corte: 25 de octubre de 2026, Costa Rica

Repositorio: https://github.com/WGuillenDev/laboratorio-pruebas-seguridad

El informe documenta una campaña de pruebas sobre expedientes académicos ficticios. Presenta los resultados del bloque de Wilberth y deja identificadas las actividades pendientes de Jania. La decisión provisional es no liberar el sistema hasta completar y verificar los controles abiertos.

Estado: versión editable en revisión. Las actividades pendientes de Jania y el cierre del equipo se completarán antes de exportar el informe final a PDF.

Contenido

1 Portada

2 Descripción del alcance activos flujo de datos y amenazas priorizadas

3 Requisitos verificables criterios de aceptación y matriz de trazabilidad

4 Diseño de los doce casos y explicación de los dos ciclos TDD

5 Acta de inspección evaluación de usabilidad registro de hallazgos y conclusiones

6 Indicadores calculados decisión de liberación y limitaciones del estudio

2 Descripción del alcance activos flujo de datos y amenazas priorizadas

2 1 Alcance

El laboratorio local gestiona dos expedientes sintéticos: 101 de Ana, sede Central, nota inicial 82; y 202 de Luis, sede Pacífico, nota inicial 91. Se evalúan lectura, cambios de nota, sesiones, confidencialidad de respuestas y auditoría. Se excluyen sistemas reales, autenticación de producción, despliegue, carga y persistencia externa.

Wilberth tiene asignados TC-01, TC-03, TC-04, TC-05, TC-07 y TC-12. Jania tiene asignados TC-02, TC-06, TC-08, TC-09, TC-10 y TC-11. Las revisiones cruzadas y el cierre requieren participación de ambos.

2 2 Activos

ID	Activo	Propiedad a proteger
A-01	Expedientes: identidad del titular, sede e identificador	Confidencialidad e integridad
A-02	Notas académicas, entre 0 y 100	Integridad y confidencialidad
A-03	Sesiones y tokens sintéticos con indicadores de revocación/expiración	Validez del acceso y confidencialidad
A-04	Permisos definidos por rol, identidad y sede	Integridad y autorización
A-05	Bitácora de lecturas y actualizaciones	Trazabilidad, confidencialidad de credenciales

2 3 Flujo de datos

Cliente local → servidor.py (ruta, token y JSON) → src/lab.py (sesión, permisos y validación) → estado en memoria (expedientes, sesiones y auditoría) → respuesta HTTP y JSON al cliente.

El servidor trata las entradas del cliente como no confiables. Los permisos se aplican en la lógica. Las pruebas unitarias llaman a esa lógica; la integración atraviesa HTTP real. Reiniciar el servidor restablece los datos sintéticos.

2 4 Amenazas priorizadas

R-01

Actor y abuso: Estudiante cambia el identificador para consultar otro expediente; docente consulta otra sede

Activo e impacto: A-01, A-02, A-04; Divulgación de información académica

Prioridad razonada: Alta: acceso directo a datos ajenos con una cuenta válida

R-02

Actor y abuso: Docente modifica otra sede; estudiante o administrador intenta cambiar notas

Activo e impacto: A-02, A-04; Calificaciones alteradas sin autorización

Prioridad razonada: Alta: rompe integridad y separación de funciones

R-03

Actor y abuso: Portador reutiliza una sesión revocada o vencida

Activo e impacto: A-03, A-01; Acceso que debía haber terminado

Prioridad razonada: Alta: la sesión inválida conserva acceso protegido

R-04

Actor y abuso: Docente o cliente envía una nota fuera de rango o con tipo inválido

Activo e impacto: A-02; Persistencia de datos académicos inválidos

Prioridad razonada: Alta: compromete la integridad del expediente

R-05

Actor y abuso: Persona con acceso a registros obtiene tokens o no puede atribuir una acción

Activo e impacto: A-05, A-03; Reutilización de sesión y trazabilidad insuficiente

Prioridad razonada: Alta: la bitácora no debe transformarse en un almacén de credenciales

3 Requisitos verificables criterios de aceptación y matriz de trazabilidad

3 1 Requisitos verificables

SEC-01

Requisito: Con sesión válida, estudiante lee solo su expediente, docente solo su sede y administrador ambas sedes. Lectura permitida: 200 y datos correctos. Otras lecturas: 403 sin datos protegidos y sin alterar expedientes.

Responsable: Wilberth

SEC-02

Requisito: Solo un docente de la misma sede puede modificar notas. Permitir con 200 y persistencia del valor; denegar a estudiante, administrador y docente de otra sede con 403 y expedientes intactos.

Responsable: Jania; Wilberth prueba denegaciones de estudiante/admin

SEC-03

Requisito: Lectura y modificación con sesión ausente, desconocida, revocada o expirada devuelven 401, sin datos protegidos ni cambios en expedientes.

Responsable: Jania

SEC-04

Requisito: Aceptar únicamente int/float que no sean bool y estén entre 0 y 100 inclusive. Rechazar valores fuera de rango, no finitos y tipos inválidos con 400 sin persistir. Comparar el rango sin convertir enteros grandes a float.

Responsable: Wilberth; Jania prueba los extremos válidos por HTTP

SEC-05

Requisito: Una respuesta denegada por sesión o permiso no incluye id, estudiante, sede ni nota, ni identifica al titular ajeno. Una operación rechazada conserva los expedientes.

Responsable: Wilberth, con verificación de sesiones por Jania

SEC-06

Requisito: Cada lectura y actualización permitida registra acción, identidad del usuario e identificador del expediente, sin almacenar token ni su valor.

Responsable: Compartido: Wilberth lectura; Jania actualización

3 2 Criterios de aceptación

CA-01 / SEC-01, SEC-05. Dada Ana con sesión válida y el expediente 202 de Luis, cuando solicita ese expediente, entonces recibe 403 sin campos protegidos ni nombre de Luis y todos los expedientes permanecen intactos.

CA-02 / SEC-02. Dada María, docente de Central, y el expediente 202 de Pacífico con nota 91, cuando intenta cambiar su nota a 70, entonces recibe 403 sin datos protegidos y la nota y demás campos siguen iguales.

CA-03 / SEC-03. Dada una sesión revocada, cuando solicita una lectura o modificación protegida, entonces recibe 401 sin datos protegidos y los expedientes no cambian.

CA-04 / SEC-04. Dada María con sesión válida y la nota inicial 82 del expediente 101, cuando envía -1, 101, texto, true o un entero muy grande, entonces recibe 400 y el expediente conserva su estado. Los límites 0 y 100 se aceptan y persisten al verificarlos en el bloque de Jania.

3 3 Matriz de trazabilidad

ID SEC	Riesgos	Casos	Evidencia prevista
SEC-01	R-01	TC-01 TC-03 TC-04 TC-05	Unidad y HTTP de lectura
SEC-02	R-02	TC-02 TC-06 TC-07 TC-10 TC-11	Persistencia y denegaciones
SEC-03	R-03	TC-08 TC-09	TDD de sesión y HTTP
SEC-04	R-04	TC-02 TC-10 TC-11 TC-12	Límites y entradas inválidas
SEC-05	R-01 R-02 R-03	TC-04 TC-05 TC-06 TC-07 TC-08 TC-09	Respuesta y estado
SEC-06	R-05	TC-01 TC-02 TC-03 TC-10 TC-11	Eventos sin tokens

El anexo matriz_trazabilidad.csv contiene los diseños completos, responsables, estados y vínculos con evidencias. Los IDs coinciden con los casos de este informe y hallazgos.csv.

4 Diseño de los doce casos y explicación de los dos ciclos TDD

4 1 Diseño de los doce casos

Se planifican 3 casos positivos, 6 negativos y 3 de frontera. El mínimo de 8 automatizados y 4 HTTP manuales se completará al integrar ambos bloques. Las variantes no se contabilizan como casos adicionales.

TC-01 Estudiante lee su expediente con auditoria segura

Tipo: positivo. Modalidad: unidad automatizada. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-01;SEC-06. Riesgos: R-01;R-05.

Precondiciones: Estado nuevo; Ana con sesion valida; 101 nota 82

Entradas: lab-ana; expediente 101

Pasos: Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -k tc01 -v; comparar respuesta completa y expedientes; comprobar evento de auditoria

Esperado: 200; contenido correcto; expedientes intactos; evento lectura/ana/101 sin token

Observado: Aprobado en ambas corridas; verificado tambien por Wilberth en captura

Estado: aprobado

Evidencia: evidencias/wilberth_unidad_corrida1.txt; evidencias/wilberth_unidad_corrida2.txt; evidencias/verificacion_wilberth.png

TC-02 Docente cambia una nota de su sede y registra el evento

Tipo: positivo. Modalidad: unidad automatizada. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-02;SEC-04;SEC-06. Riesgos: R-02;R-04;R-05.

Precondiciones: Estado nuevo; Maria Central; 101=82 y 202=91

Entradas: lab-maria;101;nota 85

Pasos: Ampliar ejemplo original; actualizar; comprobar respuesta, persistencia, otro expediente y auditoria

Esperado: 200; 101 nota 85; 202 intacto; auditoria con usuario sin token

Observado: El ejemplo original verifica 200 y nota devuelta; faltan persistencia/auditoria del caso completo

Estado: no ejecutado

Evidencia: Pendiente: evidencia de Jania con ID de caso, comandos, entorno y salida

TC-03 Administrador consulta ambas sedes

Tipo: positivo. Modalidad: unidad automatizada. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-01;SEC-06. Riesgos: R-01;R-05.

Precondiciones: Estado nuevo; admin valido; expedientes 101 y 202

Entradas: lab-admin;101 y 202

Pasos: Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -k tc03 -v; leer ambos; comparar datos y estado; verificar dos eventos

Esperado: 200 en ambas; datos correctos; expedientes intactos; auditoria identifica admin sin token

Observado: Ambas sedes aprobadas en dos corridas

Estado: aprobado

Evidencia: evidencias/wilberth_unidad_corrida1.txt; evidencias/wilberth_unidad_corrida2.txt

TC-04 Estudiante no consulta expediente ajeno

Tipo: negativo. Modalidad: unidad automatizada;TDD 1. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-01;SEC-05. Riesgos: R-01.

Precondiciones: Estado nuevo; Ana valida; 202 de Luis con nota 91

Entradas: lab-ana;202

Pasos: Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -k tc04 -v; comparar 403, ausencia de campos protegidos/titular y estado antes/despues

Esperado: 403; sin id/estudiante/sede/nota ni titular ajeno; expedientes intactos

Observado: Rojo inicial 200; verde y refactor aprobados; sigue pasando tras ampliar politica

Estado: aprobado

Evidencia: evidencias/tdd1_registro.md; evidencias/wilberth_unidad_corrida1.txt

TC-05 Docente no consulta otra sede

Tipo: negativo. Modalidad: HTTP manual con curl. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-01;SEC-05. Riesgos: R-01.

Precondiciones: Servidor local nuevo; Maria Central; 202 Pacifico

Entradas: GET /expedientes/202;Bearer lab-maria

Pasos: Consultar ambos expedientes como admin antes; intentar lectura como Maria; confirmar lectura legitima de Pedro; consultar ambos como admin despues

Esperado: 403 a Maria sin datos protegidos; 200 a Pedro; ambos expedientes intactos

Observado: Antes 200 con datos; despues 403 y sin filtracion; ambos expedientes intactos; Pedro 200

Estado: aprobado

Evidencia: evidencias/wilberth_api_antes.txt; evidencias/wilberth_api_despues.txt

TC-06 Docente no cambia nota de otra sede

Tipo: negativo. Modalidad: HTTP manual con curl o PowerShell. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-02;SEC-05. Riesgos: R-02.

Precondiciones: Servidor reiniciado; Maria Central; 202 Pacifico nota 91

Entradas: POST /expedientes/202/nota;Bearer lab-maria;{"nota":70}

Pasos: Leer 202 como admin; intentar cambio como Maria; leer despues como admin y comparar todos los campos

Esperado: 403 sin campos protegidos; expediente 202 intacto y nota 91

Observado: Pendiente Jania; falta control de sede en escritura

Estado: no ejecutado

Evidencia: Pendiente: evidencia de Jania con ID de caso, comandos, entorno y salida

TC-07 Estudiante y administrador no cambian notas

Tipo: negativo. Modalidad: unidad automatizada. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-02;SEC-05. Riesgos: R-02.

Precondiciones: Estado nuevo por rol; 101=82; sesiones validas

Entradas: lab-ana y lab-admin;101;70

Pasos: Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -k tc07 -v; por rol comparar respuesta y todos los expedientes antes/despues

Esperado: 403 en ambos roles; sin datos protegidos; expedientes intactos

Observado: Ambos roles aprobados en dos corridas

Estado: aprobado

Evidencia: evidencias/wilberth_unidad_corrida1.txt; evidencias/wilberth_unidad_corrida2.txt

TC-08 Sesion revocada no accede; variantes ausente desconocida

Tipo: negativo. Modalidad: unidad automatizada;TDD 2. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-03;SEC-05. Riesgos: R-03.

Precondiciones: Estado nuevo por variante; revocar sesion de docente para comprobar lectura y escritura

Entradas: Sesion revocada;token vacio;token inexistente;101;nota 70

Pasos: Documentar rojo antes de corregir; revocar; intentar leer y modificar; comparar respuesta y estado; repetir variantes; verde y refactor

Esperado: 401 en operaciones protegidas; sin datos ni cambios; tres evidencias TDD

Observado: El ejemplo original demuestra lectura 200 tras revocacion, esperado 401. Caso fallido por esa contradiccion; ampliacion y TDD 2 pendientes

Estado: fallido

Evidencia: evidencias/suite_parcial_equipo.txt; evidencias/verificacion_wilberth.png

TC-09 Sesion expirada no consulta ni modifica

Tipo: negativo. Modalidad: HTTP manual con curl o PowerShell. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-03;SEC-05. Riesgos: R-03.

Precondiciones: Servidor nuevo; lab-vencida expirada;101=82

Entradas: Bearer lab-vencida;GET /expedientes/101;POST /expedientes/101/nota;{"nota":70}

Pasos: Leer original como admin; intentar lectura y cambio con vencida; leer de nuevo como admin

Esperado: 401 en ambas; sin datos protegidos; expediente intacto

Observado: Pendiente de ejecucion por Jania

Estado: no ejecutado

Evidencia: Pendiente: evidencia de Jania con ID de caso, comandos, entorno y salida

TC-10 Aceptar limite inferior de nota

Tipo: frontera. Modalidad: integracion HTTP automatizada. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-02;SEC-04;SEC-06. Riesgos: R-02;R-04;R-05.

Precondiciones: Servidor de prueba local nuevo; Maria;101=82

Entradas: POST /expedientes/101/nota;Bearer lab-maria;{"nota":0}

Pasos: Iniciar servidor de prueba; enviar HTTP real; comprobar respuesta, GET posterior y auditoria; cerrar servidor

Esperado: 200; nota 0 devuelta y persistida; auditoria sin token; recursos cerrados

Observado: Pendiente Jania

Estado: no ejecutado

Evidencia: Pendiente: evidencia de Jania con ID de caso, comandos, entorno y salida

TC-11 Aceptar limite superior de nota

Tipo: frontera. Modalidad: integracion HTTP automatizada. Responsable: Jania. Prioridad: alta.

Requisitos: SEC-02;SEC-04;SEC-06. Riesgos: R-02;R-04;R-05.

Precondiciones: Servidor de prueba local nuevo; Maria;101=82

Entradas: POST /expedientes/101/nota;Bearer lab-maria;{"nota":100}

Pasos: Iniciar servidor de prueba; enviar HTTP real; comprobar respuesta, GET posterior y auditoria; cerrar servidor

Esperado: 200; nota 100 devuelta y persistida; auditoria sin token; recursos cerrados

Observado: Pendiente Jania

Estado: no ejecutado

Evidencia: Pendiente: evidencia de Jania con ID de caso, comandos, entorno y salida

TC-12 Rechazar extremos externos y tipos invalidos sin persistir

Tipo: frontera. Modalidad: HTTP manual con curl. Responsable: Wilberth. Prioridad: alta.

Requisitos: SEC-04. Riesgos: R-04.

Precondiciones: Servidor nuevo por variante; Maria;101=82;202=91

Entradas: POST /expedientes/101/nota;Bearer lab-maria;nota=-1;101;"ochenta";true;10 elevado a 400 (numero JSON)

Pasos: Reiniciar por variante; GET autorizado de ambos antes; POST del valor; GET autorizado de ambos despues; comparar

Esperado: 400 por variante; ambos expedientes intactos; entero grande rechazado sin convertir a float

Observado: Antes cuatro variantes persistian y texto ya se rechazaba; despues cinco variantes 400 sin cambios

Estado: aprobado

Evidencia: evidencias/wilberth_api_antes.txt; evidencias/wilberth_api_despues.txt

4 2 Explicación de los dos ciclos TDD

Primer ciclo de acceso indebido

Wilberth reforzó TC-04 antes de modificar la lógica. El rojo demostró 403 esperado frente a 200 observado. El verde añadió la condición mínima para impedir que un estudiante lea un expediente ajeno. El refactor extrajo esa condición a una función interna sin cambiar el comportamiento.

Etapa	Commit	Resultado
Rojo	4cf28d2	Una prueba falla por 403 != 200
Verde	e4cc9fc	Una prueba OK con denegación sin datos ni cambios
Refactor	9525e75	Tres pruebas relacionadas OK; sesión revocada sigue fallando en la suite completa

Evidencias: evidencias/tdd1_registro.md; resumen RGB en evidencias/tdd1_resumen_rgb.html; logs, capturas y diffs tdd1_rojo, tdd1_verde y tdd1_refactor; tdd1_suite_completa.txt y .png. Después se amplió la política de lectura para docentes por sede y administrador global. Los registros históricos conservan los nombres de prueba de cada commit.

Segundo ciclo de validez de sesión

Pendiente de Jania. TC-08 ya demuestra lectura permitida tras revocación. Debe ampliar la prueba, conservar el rojo, aplicar la corrección mínima y refactorizar con evidencia de las tres etapas. No se considera completado.

4 3 Ejecución y regresión

Ejecución	Resultado observado
Unidad antes de corregir auditoría	4 métodos; fallan TC-01 y TC-03 por identidad ausente. Tres aserciones fallidas contando los subcasos de TC-03
Bloque Wilberth corrida 1	4 de 4 métodos aprobados, proceso nuevo
Bloque Wilberth corrida 2	4 de 4 métodos aprobados, proceso nuevo
Suite parcial del equipo	6 métodos: 5 aprobados y 1 fallido por sesión revocada
TC-05 HTTP	Antes 200 con datos de otra sede; después 403 sin datos, estado intacto y acceso legítimo de Pedro 200
TC-12 HTTP	Antes persistían cuatro variantes inválidas; después las cinco reciben 400 y ambos expedientes quedan intactos

Entorno: Windows, Python 3.14.7, unittest y curl.exe; biblioteca estándar

Comando de Wilberth: python -m unittest discover -s tests -k SeguridadWilberth -v

Comando de toda la suite: python -m unittest discover -s tests -v

Logs: evidencias/wilberth_unidad_antes.txt, wilberth_unidad_corrida1.txt, wilberth_unidad_corrida2.txt, suite_parcial_equipo.txt y wilberth_api_antes/despues.txt. Incluyen entorno, fecha, comandos y resultados reales. Cada prueba crea estado nuevo y las peticiones HTTP reinician servidor por variante. Las dos corridas parciales no sustituyen las dos finales completas tras integrar a Jania.

Wilberth confirmó 4 de 4 pruebas propias y el único fallo de la suite completa en verificacion_wilberth.png. Sus capturas verificacion_http_denegaciones.png y verificacion_http_estado.png muestran 403 entre sedes, 400 para nota 101 y consulta posterior 200 con nota 82 conservada.

5 Acta de inspección evaluación de usabilidad registro de hallazgos y conclusiones

5 1 Acta de inspección

La inspección cruzada está pendiente. Una persona distinta del autor revisará una política y dos casos, y registrará al menos tres observaciones verificables con severidad y acción. La lectura asistida del código no sustituye esta actividad humana.

Campo	Registro pendiente
Revisor y fecha	[Completar por quien realiza la inspección]
Autor del objeto	[Completar]
Objetos	Política de lectura y dos casos de Wilberth; luego política de escritura y dos casos de Jania
Comprobaciones	Efecto sobre datos, independencia y capacidad de fallar al fallar el control
Estado	No realizada; confirmar observaciones y acciones

O-01

Objeto: Prueba de consulta propia

Observación y severidad: La prueba base solo verificaba identidad y 200. Ahora comprueba respuesta completa, invariancia y auditoría sin token. Media: el oráculo anterior no detectaba defectos de trazabilidad

Acción y estado: Implementado; pendiente confirmación por Jania

O-02

Objeto: Prueba de acceso ajeno

Observación y severidad: El test ahora usa copia profunda, ausencia de campos protegidos y mensaje diagnóstico con recurso concreto. Media: evitar que un 403 con datos filtrados se considere suficiente

Acción y estado: Implementado; pendiente confirmación por Jania

O-03

Objeto: Política de lectura

Observación y severidad: El control inicial solo trataba estudiantes y permitía docentes de otra sede. Alta: lectura académica no autorizada

Acción y estado: Corregido con política explícita; pendiente inspección por Jania

Revisión estática realizada

Se inspeccionaron permisos, validación, manejo de errores, exposición de datos y auditoría sin ejecutar el código. La lectura por rol/sede, la validación de notas y la

auditoría de lectura están corregidas. Permanecen pendientes la sede en escritura, la validez de sesión y la auditoría de actualizaciones. Lista completa: evidencias/revision_estatica.md. Las solicitudes HTTP son pruebas dinámicas, no análisis estático.

5 2 Evaluación de usabilidad

El 403 actual, «Operación denegada», no revela titular, sede ni nota; es genérico y poco orientativo. El 401, «No autenticado», tampoco divulga datos, pero no indica cómo recuperar acceso y aún no se aplica a una sesión revocada. Jania debe revisar claridad y funcionamiento de ambos controles al completar su bloque.

Se ajustaron al menos dos pruebas: TC-01 incorpora ID, respuesta completa, invariancia y auditoría; TC-04 incorpora ID y requisito, campos protegidos, copia profunda y diagnóstico específico. Los ayudantes centralizan el oráculo y cada variante de TC-07 inicia un estado nuevo.

Reproducibilidad	**Registro pendiente**
Ejecutor	Jania u otra persona distinta del autor de la suite
Fecha y entorno	[Completar]
Procedimiento	Ejecutar usando únicamente README y restablecer datos
Resultado y dificultades	[Completar con lo observado]
Acción en README	[Completar con cambios y evidencia]

5 3 Registro de hallazgos

El anexo hallazgos.csv contiene el detalle completo. H-01 y H-02 se detectaron sobre 3a27a6f; H-03 a H-05 sobre el corte W1, posterior a 9525e75 e identificado por hashes. Fecha de los hallazgos: 25/10/2026. Entorno: laboratorio local, Windows y Python 3.14.7. Los datos y tokens son ficticios.

H-01 Expediente academico ajeno

Requisito: SEC-01. Caso: TC-04. Responsable: Wilberth. Estado: corregido y verificado.

Reproducción: Estado inicial; Ana con sesion valida; expediente 202 de Luis; Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -v; observar test_rojo_estudiante_no_consulta_expediente_ajeno

Esperado y observado: 403 al solicitar el expediente ajeno / 200; AssertionError: 403 != 200

Impacto y severidad: Lectura no autorizada aceptada por el servicio; Alta: una estudiante obtiene respuesta de exito al consultar un expediente ajeno; el control de autorizacion no deniega la operacion

Tratamiento y verificación: Condicion de autorizacion de estudiante incorporada en e4cc9fc y extraida a funcion interna durante refactor; comprobados 403, ausencia de campos protegidos e invariancia de expedientes en TC-04; TC-04 pasa en verde y refactor; regresion relacionada 3/3 OK; suite completa 3 aprobadas y 1 fallo conocido de H-02; ver evidencias/tdd1_registro.md

Evidencia: evidencias/ejecucion_inicial.txt; evidencias/resumen_ejecucion_inicial.md; evidencias/tdd1_registro.md; evidencias/tdd1_rojo.txt; evidencias/tdd1_verde.txt; evidencias/tdd1_refactor.txt; evidencias/tdd1_suite_completa.txt; evidencias/wilberth_unidad_corrida1.txt

H-02 Sesiones y expedientes academicos

Requisito: SEC-03. Caso: TC-08. Responsable: Jania. Estado: abierto.

Reproducción: Estado inicial; revocar lab-ana y consultar expediente 101; Desde entrega/laboratorio_seguridad ejecutar python -m unittest discover -s tests -v; observar test_rojo_sesion_revocada_no_permita_lecturas

Esperado y observado: Revocacion 200 y lectura posterior 401 / Revocacion 200 y lectura posterior 200; AssertionError: 401 != 200

Impacto y severidad: La revocacion no impide una lectura protegida posterior; Alta: una sesion revocada conserva acceso de lectura a recursos protegidos

Tratamiento y verificación: Pendiente: Jania documentara su ciclo TDD y corregira la comprobacion de validez de sesion; cierre pendiente

Evidencia: evidencias/ejecucion_inicial.txt; evidencias/resumen_ejecucion_inicial.md; evidencias/tdd1_suite_completa.txt; evidencias/suite_parcial_equipo.txt

H-03 Expedientes y permisos de lectura

Requisito: SEC-01;SEC-05. Caso: TC-05. Responsable: Wilberth. Estado: corregido y verificado.

Reproducción: Maria Central solicita expediente 202 Pacifico; Iniciar servidor limpio; GET /expedientes/202 con Bearer lab-maria

Esperado y observado: 403 sin datos protegidos; estado intacto / Antes: 200 con expediente de Luis; despues: 403 sin campos protegidos; estado intacto

Impacto y severidad: Docente accede a datos de otra sede; Alta: divulga informacion academica de otra sede

Tratamiento y verificación: Politica _puede_leer exige sede del docente; solo administrador global; TC-05 por HTTP: 403 para Maria y 200 para Pedro; expedientes intactos

Evidencia: evidencias/wilberth_api_antes.txt; evidencias/wilberth_api_despues.txt

H-04 Notas academicas

Requisito: SEC-04. Caso: TC-12. Responsable: Wilberth. Estado: corregido y verificado.

Reproducción: Docente autorizado envia -1,101,true o entero muy grande; Servidor limpio por variante; POST /expedientes/101/nota con lab-maria; comparar ambos expedientes por GET admin

Esperado y observado: 400; expedientes intactos / Antes: cuatro variantes 200 con persistencia; texto 400; despues: todas 400 sin cambios

Impacto y severidad: Persistencia de calificaciones invalidas; Alta: altera la integridad de notas por ausencia de rango y aceptacion de bool

Tratamiento y verificación: _nota_valida comprueba tipo sin bool y rango inclusivo sin conversion a float; TC-12: cinco variantes rechazadas; ambos expedientes intactos

Evidencia: evidencias/wilberth_api_antes.txt; evidencias/wilberth_api_despues.txt

H-05 Auditoria y sesiones

Requisito: SEC-06. Caso: TC-01;TC-02;TC-03. Responsable: Jania (pendiente escritura); Wilberth (lectura corregida). Estado: abierto.

Reproducción: Lectura o actualizacion permitida en codigo base; Inspeccionar los append de auditoria en src/lab.py; ejecutar TC-01 y TC-03

Esperado y observado: Eventos con usuario/accion/id y sin token en lectura y escritura / Antes: eventos con token y sin usuario; tests de lectura fallan; despues: lectura corregida, actualizaciones aun guardan token

Impacto y severidad: Tokens almacenados y ausencia de identidad explicita en registros; Alta: una bitacora con tokens puede facilitar reutilizacion de sesiones y no identifica el actor explicitamente

Tratamiento y verificación: Lectura corregida; Jania debe corregir auditoria de actualizaciones y verificar TC-02/10/11; Lectura verificada TC-01 y TC-03; cierre global pendiente escritura

Evidencia: evidencias/wilberth_unidad_antes.txt; evidencias/wilberth_unidad_corrida1.txt; evidencias/revision_estatica.md; evidencias/wilberth_cambios.patch

No se registraron alertas que deban clasificarse como falso positivo en este corte. El encabezado NativeCommandError de las capturas iniciales es ruido de PowerShell al redirigir stderr, no un defecto adicional del sistema. Los fallos del producto se identifican por sus aserciones.

5 4 Conclusiones

Las evidencias de Wilberth demuestran denegación de lecturas ajenas o entre sedes, rechazo de las entradas inválidas probadas sin persistencia y auditoría de lecturas sin tokens. Su ciclo TDD conserva rojo, verde y refactor con regresión. El sistema completo aún no debe liberarse porque persiste el defecto de sesión y faltan los controles y pruebas de Jania.

6 Indicadores calculados decisión de liberación y limitaciones del estudio

6 1 Indicadores calculados

Estado	Casos
Aprobado	6
Fallido	1
Bloqueado	0
No ejecutado	5
Planificados	12

Tasa de aprobación: 6 / (6 + 1) × 100 = 85.71 %

Avance: (6 + 1) / 12 × 100 = 58.33 %

Cobertura de requisitos: 6 / 6 × 100 = 100 %, según al menos una prueba válida vinculada por requisito

Una prueba válida puede fallar y detectar un defecto: SEC-03 cuenta la revocación fallida. SEC-06 cuenta las pruebas de auditoría de lectura, aunque escritura aún está pendiente. La cobertura no significa aprobación de todos los controles ni de todas las variantes. Las métricas se calculan sobre casos, no sobre métodos o solicitudes.

Aprobados: TC-01, TC-03, TC-04, TC-05, TC-07 y TC-12. Fallido: TC-08. No ejecutados por completo: TC-02, TC-06, TC-09, TC-10 y TC-11. El ejemplo de TC-02 aprueba, pero todavía no comprueba todos sus oráculos. Las cifras finales se recalcularán después de Jania.

6 2 Decisión de liberación

Dictamen provisional: NO LIBERAR. H-02 sigue abierto por sesión revocada; H-05 por auditoría de actualizaciones. La autorización de escritura entre sedes todavía debe implementarse y probarse. Una tasa alta de aprobación no compensa un fallo de sesión o autorización.

Responsable de la decisión hipotética: [Designar por el equipo]

Fecha de aprobación del dictamen final: [Completar]

6 3 Limitaciones y riesgo residual

Se trabaja con dos expedientes y cinco usuarios ficticios, datos en memoria y sesiones simuladas sin tiempo real. No se probaron carga ni concurrencia. Permanecen pendientes integración, segundo TDD, inspección cruzada y reproducción usando solo README. El mecanismo de tokens es didáctico y no acredita seguridad de producción.

Los defectos abiertos deben tratarse; no se aceptan como riesgo residual por omisión. La aceptación formal del riesgo residual al cierre, con responsable, sigue pendiente. El uso exclusivo local y los datos ficticios limitan el alcance del dictamen.

6 4 Código fuente y resultados reproducibles

Repositorio: https://github.com/WGuillenDev/laboratorio-pruebas-seguridad. El README documenta entorno, instalación, comandos y reinicio de datos. Los anexos matriz_trazabilidad.csv y hallazgos.csv mantienen los mismos IDs del informe. Evidencias antes/después y TDD están en entrega/evidencias. El ZIP equivalente y el PDF final se generarán al completar y revisar ambos bloques.

Aporte de Wilberth: Primer TDD manual y commits 4cf28d2, e4cc9fc y 9525e75; continuación asistida autorizada y verificación propia de pruebas y HTTP

Aporte pendiente de Jania: Casos TC-02, TC-06, TC-08, TC-09, TC-10 y TC-11; segundo TDD, sesiones, escritura, auditoría e integración HTTP

Cada integrante debe realizar al menos dos commits significativos en dos días distintos. Los commits actuales de Wilberth son del 25/10/2026; queda pendiente otro aporte real en una fecha diferente.

Uso de IA: se utilizó asistencia para analizar el enunciado, redactar documentación y apoyar implementación y ejecución de pruebas. Las evidencias distinguen las ejecuciones asistidas de las verificaciones de Wilberth. El equipo debe comprender y verificar sus resultados.

Este Word conserva la edición del equipo. Antes de la entrega se completarán el trabajo de Jania, el acta, reproducibilidad, dos corridas finales limpias, métricas y dictamen con responsable, y se exportará a PDF conforme al enunciado.